Processo de Segregação de Funções de TI

Documento de Especificação (Procedimento)

Ref. COBIT® – PO4.11

Índice

1. OBJETIVO 3
2. ESCOPO DO PROCESSO 3
3. OBJETIVOS DE CONTROLE COBIT 4.1 3
4. CONCEITOS 4
5. DIRETRIZES E DEFINIÇÕES DO PROCESSO 4
6. INTERFACE COM OUTROS PROCESSOS 5
7. FLUXOGRAMA 6
8. DESCRIÇÃO DAS ATIVIDADES DO FLUXOGRAMA 6
9. MATRIZ RACI 8
10. PAPÉIS E RESPONSABILIDADES 8
11. INDICADORES 8
12. DOCUMENTOS DE APOIO 9
13. CONTROLE DE VERSÃO 9

1. Objetivo

Este processo tem como objetivo implementar e manter uma separação de papéis e responsabilidades que reduza a possibilidade de um único indivíduo submeter um processo crítico assegurando que os deveres de segregação sejam aplicados fisicamente e logicamente quando apropriado, assim como a manutenção da segregação periodicamente.

2. Escopo do Processo

O escopo do processo de Gestão de Segregação de Funções da Smiles cobre os processos de gerenciamento da área de TI – Tecnologia da Informação da Smiles.

3. Objetivos de Controle COBIT 4.1

Processo / Objetivos de Controle	Situação	Análise sobre o processo atual
PO4 - Definir os Processos, a Organização e os Relacionamentos de TI		
PO4.11 - Segregação de Funções Implementar uma separação de papéis e responsabilidades que reduza a possibilidade de um único indivíduo subverter um processo crítico. A gerência também deve se certificar de que o pessoal esteja executando apenas tarefas autorizadas relevantes aos seus respectivos cargos e posições.	**Contemplado**	Procedimento formal para gerenciar Segregação de Funções estabelecido por este processo.

4. Conceitos

Os principais conceitos referentes ao processo de Gestão de Segregação de Funções de TI são:

- **Segregação de Funções:** refere-se a práticas onde o conhecimento e/ou privilégios necessários para se completar um processo são quebrados e divididos entre múltiplos usuários de forma que apenas um seja capaz de executá-lo ou controla-lo sozinho.
- **Atividade Crítica:** equivale a realizar uma tarefa ou a um trabalho na sua forma ativa fundamental para realizar uma tarefa.
- **Processo Crítico:** equivale ao conjunto definido de passos para realizar uma tarefa crítica, ou aquelas que mais impactam os negócios e afetam os clientes.
- **Dono do Processo:** equivale a um papel exercido por um Colaborador Smiles com pleno conhecimento das atividades e funções exercidas em um determinado processo de gestão.

5. Diretrizes e Definições do Processo

O processo de Gestão de Segregação de Funções de TI possui as seguintes diretrizes e definições:

- **Definição única de Processo**: haverá apenas um único processo de Gestão de Segregação de Funções de TI para a Smiles. O processo de Gestão de Segregação de Funções de TI deve prevenir a realização e ocultação de fraude e erro no curso normal das atividades, uma vez que havendo mais de uma pessoa para realizar uma atividade se minimiza a oportunidade de transgressões e aumenta as chances de se detectá-la, assim como de se detecta erros não intencionais.
- **Atividades Críticas:** É responsabilidade do Dono do Processo documentar e revisar sob demanda uma relação com todas as atividades do Sistema Critico identificando as Atividades Críticas para o sucesso da operação sistêmica.
- **Classificação de Atividades por Função:** É responsabilidade do Dono do Processo documentar e revisar sob demanda a Classificação de Função de todas as atividades na relação de Atividades Críticas.

  As funções de segregação a serem aplicados são:

  - **Inicia Atividade**
  - **Executa Atividade: “**Não Autoriza” e “Não Valida”
  - **Autoriza Atividade:** “Não Executa” e “Não Valida”
  - **Valida Atividade: “Não**

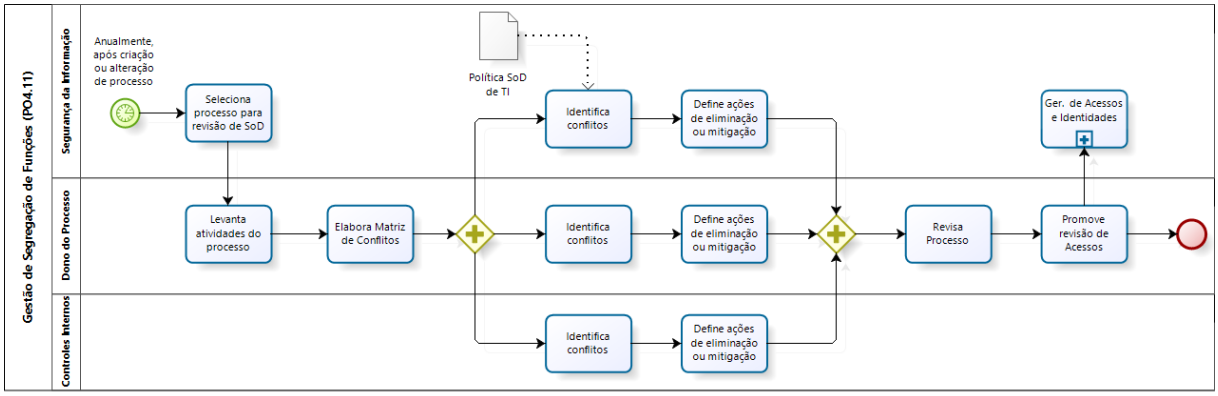
- **Segregação de deveres e responsabilidades:** É responsabilidade do Dono do Processo definir e revisar sob demanda responsáveis por cada atividade e seus substitutos para períodos em que o responsável regular não está disponível (Ex: Férias, doença ou ausências)

- **Avaliação de Impacto em Funções Críticas:** É responsabilidade da equipe de Segurança da Informação avaliar trimestralmente o impacto de Funções e solicitar a adequação de funções conflitantes aos Donos de Processos.

6. Interface com outros processos

- **Gerenciamento de Identidade**
    - Alterações nas equipes técnicas de TI são gatilhos para alterações de responsabilidades por funções de Processos.

7. Fluxograma



8. Descrição das Atividades do Fluxograma

Passo	Atividade	Executor	Descrição	Passo Seguinte
01	Seleciona Processo para revisão de SoD	Segurança da Informação	Nesta atividade Segurança da Informação Valida Relação de Processos. Mensalmente ou sob demanda de Gerenciamento de Identidade, a equipe de Segurança da Informação valida existência de novos sistemas e atualiza quando necessário a Relação de Processos no Confluence com novos Sistemas indispensáveis para as atividades da organização. Caso relação de Processos não esteja atualizada, Segurança da informação atualiza a relação com novos Processos Identificados. (Segue para o passo 02) Caso a relação de Processos esteja atualizada, o Dono do Processo Valida as Atividades do Sistema. (Segue para atividade 03)	02
02	Levanta Atividades do Processo	Dono do Processo	Nesta atividade Segurança da Informação Atualiza a Relação de Processos. Após identificado novo Processo, a equipe de Segurança da Informação atualiza a relação de Processos no Confluence e valida novamente se a relação de Processos está atualizada.	03
03	Elabora Matriz de Conflitos	Dono do Processo	Nesta atividade o Dono do Processo Valida as Atividades do Sistema. Após validação de Processos atualizados, o Dono do Processo Valida as Atividades do Sistema na Relação de Atividades do Sistema Critico. Caso as atividades do Processo não estejam atualizadas, o Dono do Processo atualiza as atividades para nova validação. (Segue para o passo 04) Caso as atividades do Processo estejam atualizadas, o Dono do Processo Valida as Funções de Segregação e Deveres. (Segue para o passo 05)	04

Passo	Atividade	Executor	Descrição	Passo Seguinte
04	Identifica Conflitos	Segurança da Informação, Dono do Processo e Controles Internos	Nesta atividade o Dono do Processo Atualiza a Relação de Atividades do Sistema. Ao identificar necessidade de atualização nas atividades do Processo, o Dono do Processo Atualiza a Relação de Atividades para validação de Funções e Segregação de Deveres.	05
05	Define Ações de Eliminação ou Mitigação	Segurança da Informação, Dono do Processo e Controles Internos	Nesta atividade o Dono do Processo Valida as Funções e Segregação de Deveres do Sistema. Após validar e atualizar a relação de atividades do sistema, o Dono do Processo Valida as Funções e Segregação de Deveres garantindo a continuidade da atividade em caso de ausência do responsável primário. Caso as Funções e Segregação de Deveres não estejam atualizadas, o Dono do Processo atualiza Funções e Segregação de Deveres. (Segue para o passo 06) Caso as Funções e Segregação de Deveres estejam atualizadas, Segurança da Informação Avalia o Impacto em Funções Críticas. (Segue para o passo 07)	06
06	Revisa Processo	Dono do Processo	Nesta atividade o Dono do Processo Atualiza as Funções e Segregação de Deveres do Sistema. Ao identificar necessidade de atualização nas Funções e Segregação de Deveres das Atividades do Processo, o Dono do Processo Atualiza as Funções e Segregação de Deveres para avaliação da equipe de Segurança da Informação.	07
07	Promove Revisão de Acessos	Dono do Processo	Nesta atividade Segurança da Informação Avalia o Impacto em Funções Críticas. Ao finalizar atividades de atualização de atividades, funções e segregação de deveres pelo Dono do Processo, a equipe de Segurança da Informação Avalia o Impacto em Funções Críticas podendo solicitar correção de conflitos ao Dono do Processo. Caso seja identificado Impacto ou conflito de Funções, Segurança da informação solicita Correção de Impacto em Funções Críticas. (Segue para o passo 08) Caso não seja identificado Impacto ou conflito de Funções, Segurança da Informação Publica as atualizações. (Segue para o passo 09)	Fim

9. Matriz RACI

RACI Smiles Atividade	Gestão de Segregação de Funções de TI R = Responsible | A = Accountable | C = Consulted | I = Informed Executor | Principal Responsável | Consultado | Informado Atividades	CIO	Segurança da Informação	Dono do Processo	Controles Internos
	Responsável pelo sucesso do processo	**A**			
01	Seleciona Processo para revisão de SoD		R		
02	Levanta Atividades do Processo		R		
03	Elabora Matriz de Conflitos			R	R
04	Identifica Conflitos			R	R
05	Define Ações de Eliminação ou Mitigação			R	R
06	Revisa Processo			R	R
07	Promove Revisão de Acessos		R	C	C

10. Papéis e Responsabilidades

- **Segurança da Informação**
  - Relacionar, validar e atualiza a relação de Processos responsáveis por suportar objetivos do negócio periodicamente.
  - Avaliar e solicitar correções quando identificado impacto em Funções Críticas.
  - Publicar atualizações de Segregação de Funções no Confluence.
- **Dono do Processo**
  - Relaciona, valida e atualiza atividades dos Processos relacionados por Segurança da Informação de sua responsabilidade.
  - Relaciona, valida e atualiza funções e segregação de Deveres para cada atividade Crítica garantindo sua execução mesmo com a ausência do responsável primário.
  - Corrige Impactos em Funções Críticas.

11. Indicadores

A Gestão de Segregação de Funções de TI possui a definição de alguns de Desempenho para acompanhamento de sua evolução, conforme demonstrado abaixo:

- Percentual e Quantidade de Processos revisados por Ano;
- Percentual e Quantidade de Conflitos resolvidos e/ou mitigados;

12. Documentos de Apoio

- CobiT® v4.1 (Control Objectives for Information and related Technology)
- ISO/IEC 27001 (Information Security Management Systems - Requirements)
- ISO/IEC 27002 (Code of Practice for Information Security Management)
- Política de Segregação de Funções de TI
- Template de Matriz de Conflitos

13. Controle de Versão

Versão	Data	Responsável	Principais Alterações
1.0	25/04/2017	CHACON Consultoria	Primeira versão do documento.